CHAPTER 7

Vulnerability assessment and management

The CompTIA Security+ exam covers common techniques used to identify risks and vulnerabilities. Organizations frequently assess their risks and vulnerabilities by using both formal and informal techniques, as well as technical tools.

In this chapter, we will explore how you can find exposed services and vulnerabilities on systems and devices by using port and vulnerability scanning tools. We will discuss vulnerability assessment methods, as well as ways to identify vulnerabilities by using both technical and nontechnical means. Finally, we will explore the art of penetration testing, including common techniques, types of penetration tests, and best practices for performing them.

Exam objectives in this chapter:

Objective 3.7: Implement assessment tools and techniques to discover security threats and vulnerabilities

- Vulnerability scanning and interpret results
- Tools
  - Protocol analyzer
  - Sniffer
  - Vulnerability scanner
  - Honeypots
  - Honeynets
  - Port scanner
- Risk calculations
  - Threat vs. likelihood

- Assessment types
  - Risk
  - Threat
  - Vulnerability
- Assessment technique
  - Baseline reporting
  - Code review
  - Determine attack surface
  - Architecture
  - Design reviews

Objective 3.8: Within the realm of vulnerability assessments, explain the proper use of penetration testing versus vulnerability scanning

- Penetration testing
  - Verify a threat exist
  - Bypass security controls
  - Actively test security controls
  - Exploiting vulnerabilities
- Vulnerability scanning
  - Passively testing security controls
  - Identify vulnerability
  - Identify lack of security controls
  - Identify common misconfiguration
- Black box
- White box
- Gray box

Vulnerabilities and vulnerability assessment

Vulnerabilities are weaknesses in systems, networks, applications, and other elements of an organization's security environment. Vulnerabilities can include a range of issues such as:

- Operating system issues that allow privilege escalation.
- Services that allow denial of service attacks.
- Poor coding that allows a web application to be susceptible to a SQL injection attack.
- Process issues that allow an intruder to enter a building without proper identification.

A typical server has the potential to have vulnerabilities in its operating system; in the third-party application software that it runs, including backup, remote administration, and other software; in its hardware components or the firmware that makes them work; or in the management and administration practices used by the support staff who work with it. Further vulnerabilities might exist in the network switches and routers the server uses to communicate to the outside world, as well as the power and cooling systems it relies on to function. With this broad range of potential vulnerabilities, it can be almost impossible to be sure that all known vulnerabilities are being appropriately handled via updates, workarounds, or other fixes at any point in time.

Attackers know that a software vulnerability is often the best way into a system, and they specifically target vulnerable applications and operating systems by using malware and other attack tools. Due to this, entire exploit testing packages such as the Metasploit Project have been created to provide an easy way for testers to use a variety of attacks against known vulnerabilities, providing both security staff members and attackers with a powerful tool. In other words, organizations focus on assessing vulnerabilities as part of their security program, and that is why vulnerability assessment is an important part of the CompTIA Security+ body of knowledge.

MORE INFO **WHAT IS METASPLOIT?**

The Metasploit Project resulted in the Metasploit Framework and other related commercial tools. Metasploit includes exploits, payloads that are delivered via exploits, and a complete set of tools to manage attacks against systems. More detail on Metasploit can be found at *www.metasploit.com*. We will look at Metasploit's capabilities later in this chapter when we discuss penetration testing.

Organizations conduct vulnerability assessments by using many different methods and tools in an attempt to track and avoid the risks that they face. In this chapter, we will examine vulnerability assessment concepts and methodologies, including those used for system vulnerability and threat assessments. Using the risk assessment concepts explored earlier in this book, we will look at technical means to identify vulnerable systems and services. Finally, we will delve into penetration testing, the art of breaking into systems and networks to test their security.

Risk-based vulnerability assessments



The first element of a vulnerability assessment program is a risk assessment. Of course, first you need to understand what a risk is. In this context, you can take the definition of *risk* from Chapter 1, "Risk management and incident response," as "the intersection of a threat and a vulnerability," and look at a risk as the potential that a threat will exploit vulnerabilities of a system, network, or other asset, resulting in harm. Here, threats are dangers that could result in an incident or breach.

MORE INFO **RISK ASSESSMENTS AND RISK MANAGEMENT**

We discussed risk assessments and risk management as a discipline in Chapter 1.

A wide variety of threats have to be taken into account when you are performing risk assessments. In a full assessment, physical threats such as fires, floods, and tornados would be assessed at the same time as information security threats such as information exposure, system compromise, and outages. For the CompTIA Security+ exam, we will focus on threats that affect the confidentiality, availability, or integrity of systems, networks, and other assets.

NOTE **DEFINING THREATS**

The National Institute of Standards and Technology (NIST) defines a threat as "any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. Also, the potential for a threat-source to successfully exploit a particular information system vulnerability." in the Federal Information Processing Standards (FIPS) 200 publication.

Threat assessments

Threats are defined in several ways by various organizations, but in general, a *threat* can be defined as a possible danger that might exploit a vulnerability, resulting in harm to the organization. Threats are aimed at weaknesses, which are protected by controls, as shown in Figure 7-1.

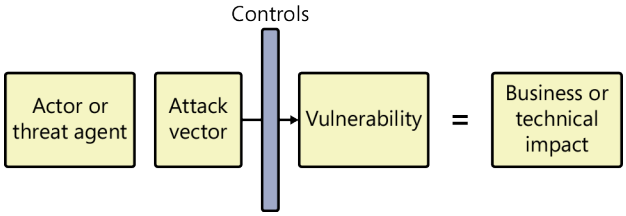


FIGURE 7-1 Threat agents attack vulnerabilities via attack vectors such as an exposed service, resulting in business or technical impact to the organization.

Threats require an actor, a vulnerability or weakness, and a motivation. This can be as simple as a tornado taking down power lines, or as complex as a group of criminals targeting vulnerable web applications in the banking industry to steal money from ATMs.

The threats an organization faces aren't always the result of attack, and most organizations assess threats that include physical threats such as fires, storms, and floods, as well as power outages, in addition to technical threats and human factors. Threat assessments build a list of the threats to an organization, allowing the organization to think coherently about what the threats it faces are.

Note that a threat may be included in a risk assessment, and in fact a threat assessment is often used as part of a risk assessment.

> ***MORE INFO*** **OWASP'S GUIDE TO ASSESSING RISKS AND THREATS**
>
> **OWASP, the Open Web Application Security Project, provides a useful example of assessing risk and threats to application security at *https://www.owasp.org/index.php/Top_10_2010-Main*.**

Vulnerability assessments

Vulnerability assessments specifically look at flaws and weaknesses in security systems, processes, controls, and designs. Thus, vulnerability assessments are targeted at the actual implementation of security, rather than considering who or what might attack, or what the

impact of the threat being realized is. Vulnerability assessments tend to follow risk and threat assessments, because they provide information about what the threats that an organization faces could result in. Performing a vulnerability assessment without performing some form of risk assessment is likely to lead to wasted effort, because low-risk areas can absorb significant amounts of time during their vulnerability assessment.

Assessment techniques

There are a variety of ways to assess vulnerabilities, ranging from code reviews that consider the source code of applications to architecture and design reviews that validate the structure of systems and applications. The CompTIA Security+ exam covers a number of common vulnerability assessment techniques. Among them are:



- *Code reviews*, which use manual or automated review of source code for programs and applications to find vulnerabilities. Code review can expose flaws that cannot be found by a vulnerability scanner, including issues with internal logic. Many organizations perform code review before releasing application code into production, but code reviews are also performed as part of vulnerability assessments, penetration tests, and after attacks as part of a remediation process.
- Determining the *attack surface* of organizations and systems. The attack surface is the collection of services, applications, and other elements of a system or organization that are exposed to potential threats. Many organizations carefully design their network to minimize their attack surface, and vulnerability assessments will verify that the actual exposed elements match the design.
- *Architecture* and *design reviews*, which focus on the architecture of applications and services. These terms are often used interchangeably because the architecture of the application or service is typically part of its design. Design reviews consider how the service was designed to work internally, including how traffic flows, where data resides, and what servers, workstations, and other network and system elements work together to provide the service or to access it.
- *Baseline reporting,* a technique that relies on the baseline security standards discussed in Chapter 6, "Monitoring, detection, and defense." Baseline reports check current settings against the baseline, then provide information about what differences, if any, exist. Baseline reporting is very useful for day-to-day monitoring of system configuration because it can easily point out issues with how security standards are applied. In some cases, changes from the baseline may mean that a system was compromised!

MORE INFO **APPLICATION SECURITY AND BASELINING**

We will discuss application baselining in Chapter 8, "The importance of application security," as part of our coverage of application security.

EXAM TIP

The CompTIA Security+ exam includes all of these assessment techniques. Make sure you know the differences between them, and why you might choose to use each.

Risk calculations: threat vs. likelihood

With these assessment methodologies in hand, you still need a way to decide which threats, risks, and vulnerabilities to pay attention to. Thus, in addition to the risk calculations explored in Chapter 1, you need one additional calculation, which is key to the CompTIA Security+ exam: the calculation of risk as the product of likelihood and impact. The equation is simple:

$R = L \times I$

Here, the likelihood is based on whether the threat appears and if it can exploit the vulnerability it is aimed at. The impact takes into account what harm the organization would experience if the threat succeeded, and should take into account the value of the assets involved.

IMPORTANT **PROBABILITY AND LIKELIHOOD**

In many risk assessment methodologies likelihood is called probability, and it isn't uncommon to see this equation as R = P × I, rather than R = L × I.

In many risk calculations, these values are simply rated as high, medium, and low, although there are many variations in ratings and scales. Some organizations rate risks in more complex ways, with scales from 1 through 10 covering multiple impact factors to finances, business operations, and reputation, while others rate everything based on the detailed calculated value of each asset.

We can use the imaginary company, Humongous Insurance, to examine this process in more depth. For Humongous Insurance, a successful denial of service attack against their website is a significant threat because it could result in lost revenue for the company. If we assume that Humongous knows that they face a real threat from a group of attackers who want to disable their site, and assuming that they have some controls in place but think they might not work, Humongous might rate the likelihood of the threat appearing and succeeding as a medium.

If we assume that Humongous Insurance makes $100,000 every 15 minutes through their website sales of insurance products, and that loss of that amount of money for hours or even a day is a significant loss to the company, we can easily calculate the impact of the risk they face. Here we will call the impact to the organization high, because they might lose customers and revenue, and suffer reputational damage.

The calculation would then be:

Risk = Medium Likelihood × High Impact

Most organizations that use this calculation use a chart similar to the chart shown in Figure 7-2, where each level of impact has been given a number from 1 through 3, with low levels listed as 1, medium as 2, and high as 3, with the values multiplied by the likelihood to give a final score. Note that a risk with a high impact and a medium likelihood would be considered a high risk (6) and would receive prompt attention.

Impact	High	3	**6**	**9**
	Medium	2	4	**6**
	Low	1	2	3
		Low	Medium	High
		Likelihood		

FIGURE 7-2 A Risk chart shows the intersection of likelihood with impact.

Example: Humongous Insurance

We can also look at Humongous Insurance for a discussion of their assessment process. For this example, Humongous wants to assess the risks, threats, and vulnerabilities to their new web application environment, which allows customers to manage their insurance products online.

First, Humongous performs a risk assessment scoped to the new environment. They will consider what risks the organization would face if the new environment was compromised, if it was offline, or if it had another failure. Their assessment of the risks involved will likely require a threat assessment, which they will base on knowledge of what threats they have seen and what their competitors have dealt with. With that knowledge in hand, Humongous can more effectively choose where to spend their time assessing vulnerabilities.

Quick check

1. **What type of assessment is intended to determine flaws that might be exploited by attackers?**
2. **What type of vulnerability assessment involves looking at the source code of the programs being assessed?**

Quick check answers

1. **A vulnerability assessment focuses on the flaws or weaknesses in systems, services, anapplications that could be exploited by attackers.**
2. **Code review is an assessment technique that uses manual review or automated tools to find vulnerabilities in source code and its internal logic.**

Vulnerability scanning

Vulnerability scans serve several purposes for organizations. Not only do they help organizations identify vulnerabilities, they also help point out when security controls have not been properly put in place, or when an attacker or misconfiguration has disabled them. They also help organizations find common misconfigurations such as default usernames and passwords, default directories and scripts that can be dangerous, and a host of other, similar issues.

Organizations typically conduct vulnerability scanning one of two ways: by using internal tools to passively scan for vulnerabilities by checking version numbers and configurations, and by active scanning using a vulnerability scanning tool. We've already discussed security baselines, which can provide *passive identification*, , so this chapter takes a look at active vulnerability scanning tools.

Vulnerability scanning tools

A key part of assessing vulnerabilities is scanning for them. This is done by using a variety of tools, including packet sniffers, port scanners, vulnerability scanners, and specialized tools such as web application vulnerability scanners. Each of these tools has a role to play in a vulnerability assessment, and they are often used together or in sequence to help provide a faster, more accurate result.

We will examine each of these tools in the order in which they are frequently used to scan systems and networks. The process typically starts with a sniffer and a port scanner, which are used to look for hosts that provide services on the network. From there, vulnerability scanners are used to find vulnerable services and systems. Finally, if you discover web applications, you might want to use a web application vulnerability scanner's specialized abilities to test it.

Protocol analyzers and sniffers

In Chapter 2, "Network security technologies," we looked at protocol analyzers and sniffers, tools that allow you to view and analyze network traffic on the wire. The capabilities that make these tools useful for detecting attacks and analyzing attack traffic also make them a useful part of vulnerability assessment.

NOTE **A SNIFFER BY ANOTHER NAME**

Remember that protocol analyzers, packet analyzers, packet sniffers, and sniffers are all names for the same tools used to read network traffic and display it.

There are a few ways in which sniffers are frequently used during vulnerability analyses and during penetration tests, which include:

- Capturing data during port scans and vulnerability scans to provide additional information about what data is being sent and received. This provides a log that penetration testers find useful to demonstrate what occurred and when. Capturing network activity can also provide more information about specific responses, allowing manual analysis if needed.
- Providing insight into the actual content of traffic sent by an attacker or attack tool, thus allowing security professionals to assess the significance of a threat. If the payload of the packets is an attack that your organization is vulnerable to, it is far more of a threat than a random attack that uses a tool you're not susceptible to.
- Analyzing the results of your own attack traffic when testing a system. This uses the same concepts as watching a third-party attack traffic but can be used inside of a network to monitor your own testing.
- Capturing traffic to determine whether network controls such as an IPS, firewall, or proxy work. A sniffer deployed at each point along the path between the sender and receiver can provide in-depth information about what traffic is permitted, and whether the network security devices are making changes to the traffic. This process is very similar to the process that many network and security professionals use when diagnosing network connectivity issues, but it changes the focus from making traffic flow to ensuring that controls work.

As you can see, sniffers are a critical part of your arsenal of tools when you are conducting vulnerability scans and penetration tests. The process for penetration testing, including the selection of tools from those discussed here, is covered in the "Penetration testing" section later in this chapter.

IMPORTANT **THE IMPORTANCE OF LOGGING**

Logging your scans by using a sniffer can be incredibly useful when your scanner is accused of causing problems such as a system crash or outage. Complete logs will allow you to provide details about which systems you were scanning at any given time and how they responded. Although it's rare, it is possible that your scan could take a system or network down!

Port scanners



One of the first tools that a security professional uses from his toolbox when starting to assess a network is a *port scanner*. Port scanners provide a quick and easy way to assess the services that are exposed on a network and can help analysts quickly get an idea of whether an organization's systems are well maintained and secured or if there are problems throughout the network.

Port scanners attempt to connect to services hosted on systems and devices on a network, and then they monitor responses. In their simplest form, they check to see which ports respond, but they can provide a variety of capabilities beyond that if they analyze the responses from the systems they receive data from.

MORE INFO **NMAP SCANNING**

Over the years, port scanners have added a range of capabilities intended to allow them to be more effective. A quick read through the Nmap guide to port scanning techniques can help you explore how many ways there are to scan a network. You can find the full list of techniques at *http://nmap.org/book/man-port-scanning-techniques.html*.

One of the major advantages of port scanners is that they can be quite fast. Unlike the vulnerability scanners we will discuss next, a port scanner is focused on a very limited set of information about systems, which helps it provide a quick list of ports and services, often with basic operating system identification thrown in. Most vulnerability scanners also limit themselves to a set of default ports, rather than scanning the full set of 65,535 ports that could be exposed to the world. Of course, scanning only part of the range of ports means that services that run on different ports might be missed!

Real world

Nmap

The network mapper Nmap is an open-source security scanner that is one of the most popular port scanners in the world. Nmap provides the ability to discover hosts, identify which ports are accessible and what state they are in, perform service identification for the services running on those ports, and determine the likely operating system of the host (see Figure 7-3). Versions of Nmap have been created for most major operating systems, making it a common choice for most security professionals who need to conduct a port scan.

In the scan shown in Figure 7-3, Nmap also identified that the scan was run against a Linux system that appeared to be running a 2.6.x branch of Linux, and that the host itself appears to be a VMWare virtual machine. You now know much more about the system, but you don't know if these services are vulnerable.

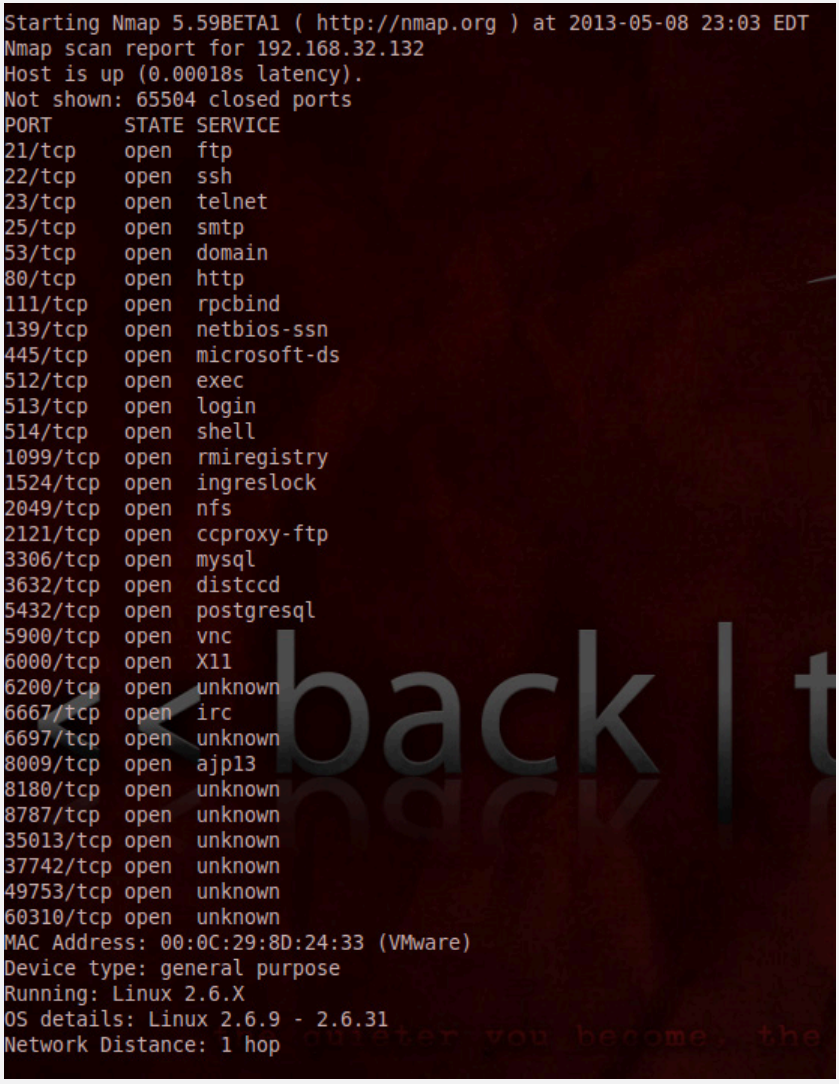


FIGURE 7-3 In this Nmap scan, a vulnerable Linux system provides a huge number of services, including FTP, SSH for remote access, SMTP email, DNS, a web server, and many other ports.

Of course, port scanning alone cannot provide a full understanding of the vulnerabilities that a system might have. When your scan completes, you will probably have useful information about potential targets, and you might even have some ideas about which systems might be vulnerable. With that data in hand, the next step for most security professionals is to scan the systems identified by a port scan with a vulnerability scanner.

Vulnerability scanners



Vulnerability scanners are the next step up in the scanning process. There are two common types of vulnerability scanners: network vulnerability scanners and web application vulnerability scanners. We'll explore each in turn.

Network vulnerability scanners

Network vulnerability scanners are designed to scan for vulnerable systems through a network. After they are provided with a target, which can be a single system, a network, or a whole range of addresses, they scan for and connect to services. This allows them to gather information about the version of the application or service running and to check it against a database of known vulnerable versions. More advanced vulnerability scanners also conduct tests to determine if specific vulnerabilities exist, either by testing for specific signs, or querying information on the system for details of what is installed. Some vulnerability scanning tools even allow you to embed administrative credentials that allow the scanner to log into systems they're scanning to verify software versions and other system settings directly.

In Figure 7-4, a scan was conducted against a sample vulnerable system by using Nessus, apopular vulnerability scanning package, resulting in a list of vulnerabilities. As you can see, the sample vulnerability selected from the scan is classified by its risk level based on the significance of the issue that would be created by exploitation of the vulnerability.

In this example, Nessus found 156 results, and the figure shows a high-security issue from that list that involves the SUDO command in Ubuntu Linux. Note that Nessus provides a description, a solution suggestion, links to details on the vulnerability itself, and information about when the vulnerability was discovered.

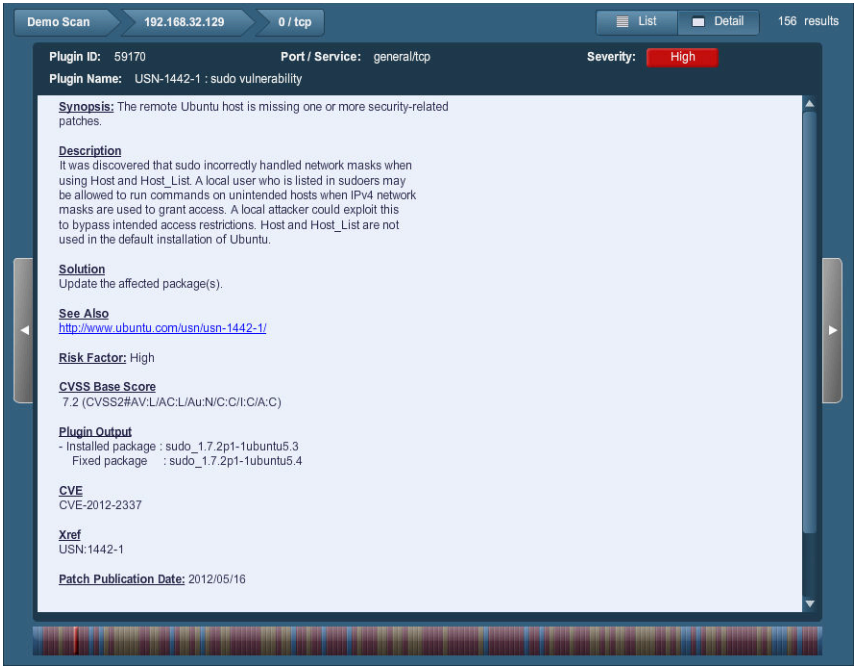


FIGURE 7-4 Nessus provides detailed vulnerability information for each vulnerability it discovers.

Web application vulnerability scanners

Web applications are the face of most organizations, and those applications can have a wide range of vulnerabilities, such as to the cross-site scripting, SQL injection, and faulty logic issues we discussed in Chapter 5, "Threats and attacks." Each application can respond differently to its users, and the way applications display data, accept input, and interact with back-end database servers can vary greatly. This means that web application assessment is a relatively specialized discipline. Until recently, most network vulnerability scanners did not have strong web application vulnerability assessment capabilities, leaving a niche for a variety of specialized *web application vulnerability scanners* (sometimes called *web application security scanners*). This is slowly changing, and major products are starting to add increasingly useful web application scanning tools to their existing vulnerability scanning products.

Web application vulnerability scanners act like an attacker might, and feed web applications bad input, change what forms send back to the application, and attempt to inject SQL statements, along with other specialized techniques. They also check for common misconfigurations, sample files and scripts, and vulnerable versions of the underlying software for websites such as their scripting engines and web servers.



EXAM TIP

The CompTIA Security+ exam expects you to know the difference between vulnerability scanning and web application vulnerability scanning. Remember that web application vulnerability scanning focuses on application and logic vulnerabilities, and vulnerability scanners look at vulnerable versions and configurations of services.

In Figure 7-5, you can see a simple open-source web application and server vulnerability scanner called Nikto. Nikto's primary focus is on web servers and common vulnerabilities in known web applications, which means it is a useful tool to check for known vulnerabilities. Unlike more complex scanners, Nikto doesn't provide an in-depth scanning tool for custom applications.

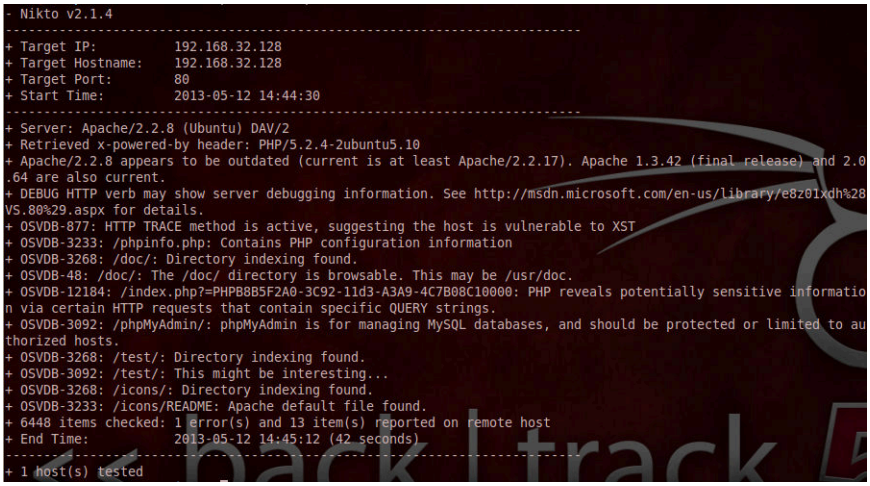


FIGURE 7-5 This Nikto scan identified the system as an Ubuntu Linux server running Apache 2.2.28 with PHP 5.2.4, which is outdated. In addition, Nikto identified multiple vulnerabilities listed in the Open Source Vulnerability Database (OSVDB) that could be issues or misconfigurations.

More complex scanners include internal logic that can analyze custom web applications and can identify vulnerabilities in how they handle input and user interaction. In Figure 7-6, the open-source Web Application Attack and Audit Framework (w3af) scanner has been run against a vulnerable application. Unlike Nikto, it explored the full application and attempted to feed it a variety of input.

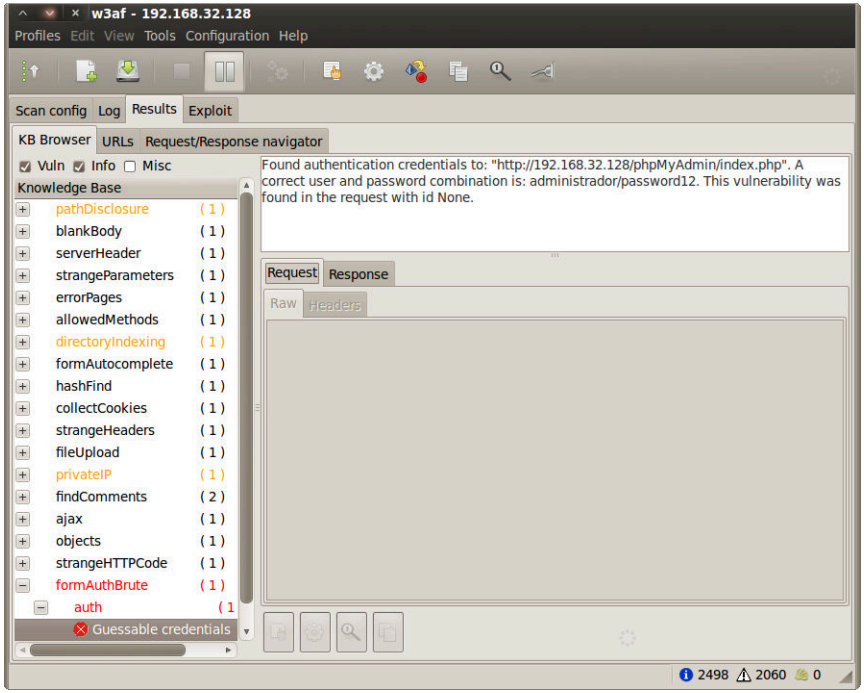


FIGURE 7-6 w3af provides far more information about vulnerabilities in the application than Nikto does.

In the example scan shown in the figure, you can see a list of issues with descriptions. Theselected vulnerability that is marked by red text provides more information, including the user name and password for a vulnerable phpMyAdmin installation on the target system.

> ***NOTE*** **WHEN AUTOMATED TOOLS AREN'T ENOUGH**
>
> **Automated tools provide many features and don't get bored while scanning, but in many cases it takes a human to fully understand the internal logic of a web application. Thus, although web application scanning tools are a useful part of a vulnerability management program, you may still want to engage a talented web application assessment tester if it is absolutely critical that your web applications are secure.**

No matter what type of vulnerability scanner you use, you should bear in mind that scanners are rarely 100 percent accurate. Vulnerability scanning is a useful tool as part of a strong vulnerability management program, and is a key part of a defense in depth strategy, but it isn't enough protection on its own.

MORE INFO **COMPARING WEB VULNERABILITY SCANNERS**

Shay Chen's 2012 Web Application Vulnerability Scanner comparison tested a variety of the most popular vulnerability scanning tools available today and found that none of them identified all of the vulnerabilities he was testing for. You can find his full report at *http://sectooladdict.blogspot.com/2012/07/2012-web-application-scanner-benchmark.html*.

Quick check

1. **What type of tool would you use to monitor the traffic sent by a vulnerability scanner?**
2. **How do web application vulnerability scanners differ from network vulnerability scanners?**

Quick check answers

1. **A sniffer or packet analyzer is typically used to monitor the packets sent by a vulnerability scanner or port scanner. This allows you to see what is sent and received by the scanning system, providing useful information about what systems were scanned and how they responded.**
2. **Web application vulnerability scanners focus on internal logic, vulnerabilities in how applications handle user input that allow attacks such as cross-site scripting, SQL injection, and similar problems. Vulnerability scanners typically look for vulnerable services and configuration issues and typically don't understand how the applications themselves work or handle user input.**

Honeypots and honeynets



The CompTIA Security+ exam looks at two types of systems designed to lure attackers into targeting them: *honeypots* and *honeynets*. Honeypots are specially designed systems and applications that expose tempting interfaces and vulnerabilities to potential attackers. Often they will provide a complete copy of a legitimate vulnerable system, but will be designed in a way that prevents attackers from gathering actual data or performing further attacks. Instead, they gather information about what the attackers do and how they do it. Most honeypots log every action taken on the system, and many also keep copies of files and tools that attackers bring with them.

Honeypots are often classified into one of two types:

- Low-interaction honeypots, which provide a few commonly targeted services and are focused on studying the most heavily attacked applications and systems
- High-interaction honeypots, which emulate an entire operating system or application, allowing attackers to perform the actions they normally would on a compromised system

Honeynets work much like honeypots do, but on a much broader scale: they are entire networks of systems designed to lure attackers in. This means that some honeynets can detect attacks in a variety of locations or attacks aimed at a variety of systems on a network.

Network honeypots are often called *sinkholes*. Much like honeypots, sinkholes are designed to absorb attacks safely while providing researchers and security professionals with a chance to study malicious traffic.

MORE INFO **THE HONEYNET PROJECT**

Information security researchers around the world contribute to the Honeynet Project, a collaborative network of honeypots run through a nonprofit coordinating body. More information about the Honeynet Project can be found at *www.honeynet.org*.

Organizations might deploy honeypots or honeynets for research, allowing them to understand new threats, or for production use, to help detect attacks and new threats on their own internal networks. In addition to the honeynets and honeypots the CompTIA Security+ exam focuses on, two other common security tools exist, with related uses: darknets and tarpits.

Darknets

Darknets are segments of unused network space that host no servers and provide no services. Thus, no traffic should be sent to them, because they don't advertise anything that should result in connections. This means that any network traffic sent to the darknet IP addresses is suspect and is likely to be of interest to security professionals.

Darknets typically host one or more systems that collect all network traffic sent to the network. When the traffic is captured, it can be analyzed to detect port scans such as those discussed earlier in this chapter. Darknets have been used to detect worm outbreaks, misconfigured systems, and a host of other abnormal network traffic.

MORE INFO **REAL-WORLD DARKNETS**

Team Cymru, a nonprofit security research organization, runs an extensive darknet to capture probes, malware, and other attacks that randomly attack IP addresses on the Internet. More details on the Darknet project can be found at *www.team-cymru.org/Services/darknets.html*, where you can access full instructions on how to set up your own darknet server.

Tarpits

In addition to detecting scans, some organizations prefer to slow down scanners. Tarpits are the answer. A *tarpit* is a system specifically configured to delay network connections such as those made by a worm that is scanning for new systems to compromise, or a network vulnerability or port scanner that is searching for services.

Tarpit implementations can be as simple as an increased delay for connections to an email server, and as complex as a dedicated server that responds to every connection to a subnet with a variety of connection messages, resulting in scanners taking hours to scan, only to return a list of fake services and systems.

IMPORTANT **WHY TARPITS AND DARKNETS?**

Though the CompTIA Security+ exam doesn't cover darknets, tarpits, or sinkholes, the concepts behind them are useful for security professionals to keep in mind when learning about how attackers can be monitored, stopped, and studied.



EXAM TIP

The CompTIA Security+ exam covers honeypots and honeynets. Simply remember that ahoneypot is a single system, and that a honeynet is more than one system, typically deployed in various network locations.



Quick check

1. **What type of network security tool is designed to allow attackers to break in and interact with the operating system so that security professionals can learn about their behavior?**
2. **Why might you deploy a honeynet?**

Quick check answers

1. **A high-interaction honeypot is designed to provide a simulated, safe target for attackers that reacts like a real system would.**
2. **Honeynets are useful for detecting attacks that are distributed across a network or that occur in more than one location. Honeynets can help security professionals determine the scope and size of a scan or attack by capturing traffic in a variety of locations.**

Penetration testing



Penetration testing is the process of attacking an organization to test its technical security, practices, procedures, and other defenses. Penetration tests are conducted by, or for, organizations that want a real-world test of their security. Unlike actual attacks, penetration tests are conducted with the knowledge of the organization, although some types of penetration tests occur without the knowledge of the employees and departments being tested.

Penetration tests are typically used to verify threats or to test security controls. They do this by bypassing security controls and exploiting vulnerabilities, using a variety of tools and techniques, including the attack methods discussed earlier in this book. Social engineering, malware, and vulnerability exploit tools are all fair game when it comes to penetration testing.

IMPORTANT **PENETRATION TESTING AND THE COMPTIA SECURITY+ EXAM**

The CompTIA Security+ exam focuses on the use of penetration testing for these purposes. Penetration tests actively test security controls by exploiting vulnerabilities and bypassing security controls, and this helps to verify that a threat exists.

Penetration tests are often classified as overt or covert and as internal-perspective or external-perspective tests. Overt penetration tests are intended to be visible to members of the organization being tested, and use techniques that are likely to be detected by security tools, system administrators, and security professionals. Covert tests better simulate more stealthy attacks and attempt to evade detection. Tests with an internal perspective or view are conducted from inside an organization's security perimeter, whereas external-perspective tests are conducted from outside that perimeter. Note that the designation of a test as an internal-perspective test does not imply that the testers were allowed past that perimeter. One common technique for penetration testers is to bypass external security perimeters physically by placing devices inside an organization.

Real world

My Little Pwnie Plug

Pwnie Express (pronounced "Pony Express") is a company that specializes in penetration testing hardware. Among their products are penetration testing aids known as the Pwn Plug and the Power Pwn (see Figure 7-7), which are designed to help bypass security perimeters.



FIGURE 7-7 The Pwn Plug looks like a common power adapter.

The Pwn Plug resembles a common "wall wart" power adapter but conceals a small Linux computer complete with flash memory, network adapters, and penetration testing software packages preloaded. The Pwn Plug shown in Figure 7-7 is an innocuous device that penetration testers can plug into any power outlet in buildings to which they can gain access. Once there, it can connect to wireless and wired networks, perform vulnerability testing with a variety of built-in open-source tools, and provide an encrypted tunnel in for penetration testers. The device even includes a set of stickers intended to make it look more like a common power adapter. Most of the staff in your organization would probably not think twice about a Pwn Plug.

Devices such as the Pwn Plug aren't the only way in for penetration testers. Other recent techniques include seeding parking lots with USB flash drives that contain malware that phones home to the testing team after they're plugged into a workstation, using social engineering techniques to persuade staff members into allowing the penetration testers themselves to access their PCs, and a host of other techniques.

Types of penetration tests

The CompTIA Security+ exam divides penetration tests into three major types of testing, classified by how much information the testers have. The categories are black box, white box, and gray box testing. We'll take a look at each of them, and then we'll explore how they are performed.

Black box penetration testing



Black box penetration tests, sometimes called *blind penetration tests*, are conducted with no knowledge of the environment. They are much more difficult to conduct than white box or gray box vulnerability tests, because they require the penetration testers to gather any information they need about an organization by themselves.

This makes black box penetration tests a far better test of what an actual attacker might manage to do. Because black box testing is as close to a real-world attack as possible, some organizations opt to use black box penetration tests to test their own defenses against attackers. As you might imagine, a black box penetration test is typically far more expensive in terms of both time and effort than tests that provide attackers with more knowledge. Worse, black box testing can leave entire sections of an IT infrastructure alone if the attacker misses them when scanning for targets.

White box penetration testing



White box penetration tests provide the most information to the penetration testing team. Because white box testing provides a complete and unobstructed view of the environment tothe attacker, it is sometimes called *crystal box penetration testing*.

White box penetration testing provides several advantages:

- More focus is placed on the test itself, rather than on gathering information.
- More in-depth testing can be accomplished, because everything that can be tested is exposed.
- Attacks against known systems and services are more likely to be the right attack and to demonstrate true issues with the systems and services.

White box testing can be very helpful in identifying vulnerabilities that might be missed by a black or gray box test, but they can add additional cost because of the broader scope that total visibility can create.



EXAM TIP

If you can't recall what information is available during a penetration test, remember that the color of the box tells you all you need to know. You can't see through a black box, but the white (crystal) box shows you everything.

Gray box penetration testing



Gray box penetration testing is a middle ground between black box testing and white box testing. Gray box testers typically receive partial information about the subjects of their testing but don't have access to every detail of the target. Gray box testing can help avoid some of the problems with black box testing by ensuring that important parts of the target aren't missed. It can also prevent the common white box testing issue of not replicating an actual attack scenario.

NOTE **GRAY BOXES: PARTIAL KNOWLEDGE TESTING**

Gray box testing is sometimes called "translucent box" testing, a halfway point between white box testing's "crystal box" and black box testing's "blind" testing.



Quick check

1. **A penetration that that is performed with full knowledge of the systems, network, and defenses of a target is known as what type of penetration test?**
2. **What are the advantages and disadvantages of a black box penetration test?**

Quick check answers

1. **A white box, or crystal box penetration test provides full knowledge of the environment being tested to the attackers. This allows them to more fully test the environment, but it does not simulate a real-world attacker's view of the systems.**
2. **Black box penetration tests provide a real-world test by providing no internal knowledge of the organization or systems that are being tested. This can result in systems being missed due to lack of knowledge.**

Conducting a penetration test

After you have decided on the type of penetration test that will be conducted, a complex process still awaits. Thorough penetration testing can be very involved, and using a standard process can help keep the test from causing issues or breaking down midway through.

A typical penetration test will use most of the following steps:

1. Documentation of the request for the penetration test, including the authority under which it will be performed, its scope, and who the audience for the results will be
2. Planning and design
3. Identification of the targets of the test

4. Selection of methods and tools
5. Vulnerability testing and validation against the target and/or security assessment of the target
6. Reporting
7. Remediation of issues discovered during the penetration test

IMPORTANT **PENETRATION TESTING AND PERMISSION**

Penetration testing should only be done with appropriate authorization. Many penetration testers and security professionals refer to this as a "Get out of jail free card," because having the right permission ensures that security testing won't get the tester fired!

Next we will explore each of these steps, including what each requires, what it involves, and what you need to know to execute each step.

Authority, scope, and audience

Three key elements to understand before you begin a penetration test are the authority under which you are conducting it, the scope of the penetration test, and who you are preparing the results for.

Penetration tests should be authorized by an appropriate member of the organization engaging the penetration tester. Often this means the CEO or CIO of an organization, or an equivalent member of management. Equally important is to have written authorization for the test.

The person or group that authorizes the test is typically the sponsor within the organization. The sponsor of a penetration test plays a key role, which usually includes coordination within the organization. In addition, the sponsor can help handle issues that arise during the penetration test, particularly if it is a black box test that staff members in the organization are not aware of.

The sponsor or sponsors of the penetration test will also help to set the scope of the test. Properly scoped tests will include appropriate systems and networks. If scope isn't well defined, or if the scope includes the wrong systems, penetration tests can cause outages or other issues. Obviously. penetration tests bear some risk even at the best of times, but proper scoping can keep those risks within the risk appetite of the organization. Scoping also helps penetration testers estimate how much effort and time they will need to complete the test, which can ensure that appropriate resources are used.

During the scoping process, testers will also typically set the rules of engagement for the penetration test. These should clearly state what the testers are allowed to do, as well as what they are prohibited from doing. If testers are not allowed to use social engineering, or cannot seed the parking lot of the facility with flash drives filled with malware, they need to know this as part of the rules. This means that the penetration testers need to carefully explain what

they will be doing to the sponsors, because sponsors are unlikely to realize the full impact of what they may authorize if they are not told.

Finally, penetration testers need to know who their report will be provided to. Often, penetration tests include both a high-level executive summary suitable for senior management as well as a more technical, in-depth report. The executive summary must provide key information about the testing and what issues were found without venturing too far into esoteric technical data. The in-depth report typically includes far deeper detail on what actions were taken, what resulted from the actions, and how vulnerabilities were verified.

If these three initial elements aren't well understood, a penetration test can fail before it starts!

Penetration test planning and design

In order to perform a thorough penetration test, you need a plan. Fortunately, several organizations provide documentation on penetration testing methodologies, including NIST's SP 800-115 Technical Guide to Information Security Testing, the OWASP (Open Web Application Security Project) guide to web application penetration testing, and the Institute for Security and Open Methodologies' (ISECOM's) Open Source Security Testing Methodology Manual, or OSSTMM.

MORE INFO **PENETRATION TESTING METHODOLOGIES**

You can find these methodologies the following sites:

- **NIST (*csrc.nist.gov/publications/nistpubs/800-115/SP800-115.pdf*)**
- **OWASP (*www.owasp.org/index.php/Web_Application_Penetration_Testing*)**
- **ISECOM (*www.isecom.org/research/osstmm.html*)**

Other methodologies exist, allowing you to choose the methodology or elements that best fit your organization's needs.

Whether you select a third-party methodology, use one to develop your own, or simply create one in house, a thorough penetration testing plan can help avoid problems. Plans help you identify tools and infrastructure, needed information and skills, and when and how the test will be conducted. A well-designed plan can reduce the potential negative impact that attacking an organization's infrastructure can have, while still allowing you to gather useful information.

Target identification

The way targets are identified for a penetration test depends on the type of test being conducted. A white box test will usually be accompanied by a list of targets, including systems, applications, and security procedures that need to be tested. Black and gray box tests provide far less information, leaving identification of targets to the penetration testing team.

Target identification without full knowledge starts with gathering information about the organization. Public information includes public websites, information from web forums, and postings that employees have made about the company. With that information in hand, the penetration tester can gather more detail, including IP address ranges, domains, and other information that can help narrow the list of potential targets.

After the penetration testers have identified a list of potential targets, they will typically conduct information-gathering exercises such as DNS queries, port scans, and sometimes vulnerability scans. Each of these can provide more detail about the systems their target exposes to the world.

MORE INFO **EXPLOIT AND VULNERABILITY DATABASES**

Knowledge is also a key component of testing for vulnerabilities. Most vulnerability assessment tools provide links to known vulnerabilities, but knowing where to find more information is important. Fortunately, large-scale exploit databases exist that can provide information about vulnerabilities, often including working exploit code and details about which versions of software packages have the vulnerability.

Some of the most popular vulnerability resource and reference sites are:

- **The Common Vulnerabilities and Exposures (CVE) dictionary run by MITRE (*cve.mitre.org/index.html*)**
- **The Exploit Database (*www.exploit-db.com/*)**
- **The Open Sourced Vulnerability Database (*www.osvdb.org/*)**
- **The National Vulnerability Database (*nvd.nist.gov/*)**

Simply entering an application's name into these reference sites can be a very informative exercise.

When they are done, penetration testers will have a list of targets with information about each. From there, they can build a list of penetration testing goals and tasks that will drive the rest of their assessment. In order to complete the assessment, they need to determine what methods and tools they will use to meet their penetration testing goals.

Methods and tools

Penetration testing methods include many of the same attacks discussed in earlier chapters but are intended to determine if a vulnerability exists, rather than to disable the organization. Thus, attacks tend to focus on vulnerability verification, with exploits used to prove that the vulnerability exits or to gain further access to allow deeper testing. Most penetration tests avoid conducting denial of service attacks, although it is possible that an organization may include them in the scope.

Methods for testing are often selected in the planning phase of the penetration test to meet the scope of the assessment. After targets have been identified, those methods can be

refined based on information gathered about the targets. If the targets are web servers, then web application testing tools and techniques would be chosen, whereas a Windows domain would require the selection of tools that focus on Active Directory and common Windows vulnerabilities.

A broad variety of tools exist for penetration testers to choose from, ranging from commercial tools to open-source packages, and those that have both commercial and open-source versions, such as the Metasploit Framework. A key part of penetration testing is selecting appropriate tools for the targets of the test.

MORE INFO **LINUX PENETRATION TESTING DISTRIBUTIONS**

In addition to commercial tools, a variety of prepackaged open-source penetration testing tools are available. Some of the most popular include:

- **BackTrack Linux (*www.backtrack-linux.org/*)**
- **Kali Linux, a recent replacement for BackTrack Linux: (*www.kali.org*)**
- **InGuardians Samurai Web Testing Framework (*samurai.inguardians.com/*)**
- **Knoppix Security Tools Distribution (STD) (*s-t-d.org/*)**
- **BugTraq (*bugtraq-team.com/*)**
- **BackBox Linux (*www.backbox.org/*)**

Penetration testing toolkits are constantly being created, and each has its strong points, so it is worth reviewing what toolkits are being actively updated at the time you need to conduct your test. If you prefer to test your skills, distributions such as Metasploitable, a product found at *http://sourceforge.net/projects/metasploitable/files/Metasploitable2/*, provide a playground for penetration testers to attack in a safe lab environment.

Vulnerability testing, validation, and assessment

The full details of how to conduct a penetration test could fill a book on their own. For our purposes, it is important to know that a penetration test should be conducted in accordance with the rules of engagement that the sponsor helped set when the assessment was scoped, and that the tester or testers must be careful to not go beyond that scope without approval.

During a penetration test, the testers will use a variety of scan, attack, and analysis tools. All of the data that is collected should be carefully logged, including notes on when each attack is conducted, what target or targets it is aimed at, and what data was gathered from the attack.

Careful logging and analysis is important, and if a team is conducting the penetration test, a method to keep the team coordinated is very important. Penetration tests can be expensive and dangerous to an organization's business and infrastructure if they are not carefully conducted, so care and diligence are critical.

Reporting

After a penetration test has been completed, a report needs to be prepared for the sponsor or sponsors. In many cases, additional technical reports will also be required for the areas in which issues were identified, because the report to the sponsor of the penetration test is typically a high-level report.

IMPORTANT **TARGETING YOUR REPORTS**

High-level reports should prioritize issues. Penetration tests can provide massive amounts of information, and understanding what your sponsor is looking for and how to best provide that data to the sponsor is key!

Reports should include the scope, the targets, the tools and methods selected and used, and information about what vulnerabilities were found and successfully validated. Reports should also include details on any vulnerabilities that were identified but that testers were unable to exploit, particularly if they were not exploited due to constraints set by the scope or rules of engagement of the test.

Reports typically include technical information as an appendix or as an additional document. This allows the sponsors to provide detail to system administrators or security staff, which will allow them to put in place appropriate controls or fixes for the issues observed during the test.

Remediation

The final stage of a penetration test is remediation. After the sponsor and those who have a stake in the test have read the report, the issues that were reported must be prioritized and acted on. In most cases, penetration tests find a variety of issues, and not all of them will be remediated due to costs, time constraints, or other reasons.

When remediation is finished, long-term monitoring and maintenance is necessary. The network monitoring techniques we discussed in Chapter 6 are important to implement to ensure that ongoing monitoring occurs. Many organizations choose to perform penetration tests on a recurring basis, and some standards and laws require them.

MORE INFO **PCI –DSS AND PENETRATION TESTING**

Requirement 11.3 of the Payment Card Industry Data Security Standard (PCI-DSS) credit card standard requires penetration tests at least annually, as well as any time a significant change is made to the credit card processing environment. In fact, the PCI Security Standards Council provides guidance that notes that all upgrades and modifications of the environment should be penetration tested! Their guidance document also suggests that the method and results should be documented to ensure that information about the testing is available. Details of this requirement can be found at *www.pcisecuritystandards.org/pdfs/infosupp_11_3_penetration_testing.pdf*.

Quick check

1. Who authorizes a penetration test?
2. What information should a penetration test report contain?

Quick check answers

1. A senior administrator such as a CEO or CIO should authorize a penetration test. Penetration tests should only be conducted with full authorization from a person who has the authority to permit them, and documentation of the authorization and scope should be retained as part of the test.
2. Penetration test reports should include the scope, methods used, and information about the issues discovered. Typically, reports should include both an executive overview and detailed information for technical staff who need to remediate vulnerabilities found during the test.

Chapter summary

- Risk is used to determine organizational priorities. You can use the equation *Risk* = *Likelihood* × *Impact*, to rate risks based on how often they occur and how much harm they would result in.
- Threats leverage vulnerabilities via attack vectors, resulting in business or technical impact. The relationship and differences between risks, threats, and vulnerabilities is important to remember: a risk is the potential that a threat will exploit vulnerabilities of a system, network, or other asset, resulting in harm. A threats is an actor that might exploit a vulnerability.
- A broad range of tools can be used for vulnerability assessment, including protocol analyzers, sniffers, port scanners, and vulnerability scanners. Protocol analyzers and sniffers are used to monitor traffic sent by other tools, and to look at responses. Port scanners and vulnerability scanners are used to actively scan systems and devices.
- The reasons for conducting vulnerability scans including identifying vulnerabilities, verifying security controls, checking for missing controls, and finding misconfigurations.
- Port scans identify accessible services, operating system versions, and other basic information about a system. Vulnerability scans check for service versions and other information about a system and compare that data to a list of known vulnerabilities. Penetration tests often take advantage of both by first scanning for open ports and then targeting specific services.
- Honeypots and honeynets are security tools that invite attackers to break in, and allow security professionals to learn their techniques and tools by capturing them.

- Organizations use assessment techniques such as baseline reporting, which checks current settings against those defined in a security baseline or template; and code review, which explores the source code of an application to ensure that it doesn't contain bugs, mistakes, or other flaws to monitor for new vulnerabilities and risks to their systems and software.
- Design and architecture review, which takes advantage of knowledge of how services, networks, and systems are put together to determine whether they are vulnerable. This also helps to assess the attack surface, which is the part of the design that is accessible to attackers.
- Penetration tests are a hands-on way to test actual vulnerabilities. Penetration tests typically follow a process that starts with authority to conduct a test, then moves through setting a scope, selecting tools, and then performing a penetration test. They typically conclude with a report, followed by application of controls or fixes to identified issues.
- Penetration test view, include black box penetration testing, which provides no data to the tester; gray box testing, which restricts available information; and white box testing, which provides full detail and visibility of the environment to those who are testing it.

Chapter review

Test your knowledge of the information in Chapter 7 by answering these questions. The answers to these questions, and the explanations of why each answer choice is correct or incorrect, are located in the "Answers" section at the end of this chapter.

1. A security tool that is designed to allow attackers to attack a simulated system and thatgathers information about the attackers' tools and techniques is known as what?
   - **A.** A vulnerability detection system
   - **B.** A port scanner
   - **C.** A darknet
   - **D.** A honeypot
2. What type of vulnerability review focuses on how systems are put together?
   - **A.** A penetration test
   - **B.** A vulnerability scan
   - **C.** A design or architecture review
   - **D.** A code review

3. The potential that a threat will exploit vulnerabilities is known as what?

   A. A risk

   B. A vulnerability

   C. A threat

   D. An exploit

4. The equation to calculate risk is:

   A. *Risk* = *Likelihood* × *Vulnerability*

   B. *Risk* = *Impact* × *Vulnerability*

   C. *Risk* = *Vulnerabilities* × *Threats*

   D. *Risk* = *Likelihood* × *Impact*

5. What type of penetration test provides partial visibility into the details of the environment to the testers?

   A. Red box

   B. White box

   C. Gray box

   D. Black box

6. What type of testing would you perform to identify services and accessible ports via a network?

   A. A port scan

   B. A penetration test

   C. A vulnerability scan

   D. A ping sweep

Answers

This section contains the answers to the questions for the "Chapter review" section in this chapter.

1. **Correct Answer: D**
   - A. **Incorrect:** Vulnerability detection system is a made-up term.
   - B. **Incorrect:** Port scanners are tools used to scan for open services.
   - C. **Incorrect:** A darknet is an unused network set up and instrumented to detect attacks—any traffic sent to a darknet is suspect, because no valid systems should exist there.
   - D. **Correct:** A honeypot is designed to allow attackers to compromise a fake system, providing the opportunity to study their actions.
2. **Correct Answer: C**
   - A. **Incorrect:** A penetration test tests a broad variety of security controls by attacking systems and networks to attempt to gain access.
   - B. **Incorrect:** A vulnerability scan scans for vulnerabilities by using a scanning tool.
   - C. **Correct:** A design or architecture review investigates the design of a system, network, or application.
   - D. **Incorrect:** A code review targets the source code of an application or service to check it for vulnerabilities and bugs.
3. **Correct Answer: A**
   - A. **Correct:** A risk is the potential that a threat will exploit vulnerabilities.
   - B. **Incorrect:** A vulnerability is a weakness in a system or asset that can be exploited.
   - C. **Incorrect:** A threat is a possible danger that might exploit a vulnerability, resulting in harm to the organization.
   - D. **Incorrect:** An exploit is a successful attack against a vulnerability, or a known method of attacking a vulnerability successfully.
4. **Correct Answer: D**
   - A. **Incorrect:** Likelihood is important to risk, but vulnerability isn't used in the calculation.
   - B. **Incorrect:** Impact is important to risk, but vulnerability isn't used in the calculation**.**
   - C. **Incorrect:** Neither vulnerability nor threats are used in the calculation of risk.
   - D. **Correct:** Risk is calculated by multiplying likelihood and impact. This makes higher-impact or higher-probability risks more important.

5. **Correct Answer: C**

   A. **Incorrect:** Red box is not a term associated with penetration testing.

   B. **Incorrect:** White box or crystal box penetration testing allows full visibility and knowledge of the penetration test target.

   C. **Correct:** Gray box penetration testing provides partial knowledge of the target.

   D. **Incorrect:** Black box testing provides no knowledge of the testing target.

6. **Correct Answer: A**

   A. **Correct:** A port scan provides information about open ports, helping to identify services on a network.

   B. **Incorrect:** A port scan is often part of a penetration test, but you are unlikely to perform a complete penetration test to identify services.

   C. **Incorrect:** Vulnerability scans search for vulnerable services but are not the best way to identify them.

   D. **Incorrect:** A ping sweep tries to ping a series of machines to see if they are online and responding to pings—something that most modern operating systems don't do by default.